

Linux Rootkit Internals

Cyber Wargame Christmas Party(大和セキュリティ) 12/23

@tkmru

自己紹介

- たけまる(@tkmru)
- ~~CTFチーム: TomoriNao~~
- 同人誌サークル: TomoriNao
- 冬コミに落ちたので同人誌に書く予定だったネタを発表します



Rootkitとは

- 作動中のプロセスやファイル、ログやシステムデータを隠すマルウェア
- ex) ps, topコマンドを隠す、マルウェア自体のファイル、プロセスを隠す
- 今回のLTで対象とするのはLinux向けのもの

GitHubにコードがある！！

- GitHubにOSSとしていろいろ公開されている
 - （多分）研究用？
 - マルウェアのコードが読める！！
- まとめ: <https://github.com/tkmru/awesome-linux-rootkits>

いろいろなLinux Rootkitたち

- LD_PRELOAD Rootkit
- Kernel Module Rootkit
- Ramdisk based Rootkit

LD_PRELOAD Rootkit

- 環境変数 LD_PRELOAD を使って共有ライブラリを差し替えることができることを使った rootkit
- ex) Jinx2, vlany, azazel

LD_PRELOADとは

- 読み込ませる共有ライブラリ(.so)のパスを設定できる環境変数
- シンボルの名前解決のとき シンボル名が衝突していると LD_PRELOADに設定している .so 内の関数を優先して読みに行く
- これによって関数を上書きでき、rootkitに用いることができる

LD_PRELOADとは

```
$ ldd $(which ls) # 動的リンクされている共有ライブラリー一覧
```

```
    linux-vdso.so.1 => (0x00007ffdc1b78000)
```

```
    libselinux.so.1 => /lib/x86_64-linux-gnu/libselinux.so.1  
(0x00007fbe97fb5000)
```

```
    libacl.so.1 => /lib/x86_64-linux-gnu/libacl.so.1 (0x00007fbe97dad000)
```

```
    libc.so.6 => /lib/x86_64-linux-gnu/libc.so.6 (0x00007fbe979e3000)
```

```
    libpcre.so.3 => /lib/x86_64-linux-gnu/libpcre.so.3  
(0x00007fbe977a5000)
```

```
    libdl.so.2 => /lib/x86_64-linux-gnu/libdl.so.2 (0x00007fbe975a1000)
```

```
    /lib64/ld-linux-x86-64.so.2 (0x000055f1ce4c8000)
```

```
    libattr.so.1 => /lib/x86_64-linux-gnu/libattr.so.1  
(0x00007fbe9739b000)
```

```
$ LD_PRELOAD=./hook.so /bin/ls # ls内の関数をフック!!
```


Kernel Module Rootkit

- Loadable Kernel Moduleを利用して、kernelの機能を書き換えるrootkit
- Kernel rootkit、LKM(Loadable Kernel Module) rootkitとも言われる
- ex) adore, suterusu, diamorphine, etc

Kernel Moduleとは

- 正面から Kernelのコードに手を入れ、機能を追加しようとする、再コンパイルしてリブートする必要がある
- Kernel Moduleを使うと、カジュアルにKernelに機能を追加できる
- 正しくはNIC等のデバイスドライバを追加するために使われる

Kernel Module Rootkit

- システムコールをフックするKernel Moduleを追加することでRootkitの機能を実現している
- 以下動作例
 - 直接該当するシステムコールをフックして処理を変更する。
 - ファイルの呼び出しをリダイレクトして、別のバイナリを実行させる。
 - 最終的に出力される情報のみを変更する。

Ramdisk based Rootkit

- initrd(初期RAMディスク)を書き換えることによる rootkit
- 割りと新しいタイプのrootkit
- ex) Horse Pill: black hat USA 2016
 - <https://www.blackhat.com/docs/us-16/materials/us-16-Leibowitz-Horse-Pill-A-New-Type-Of-Linux-Rootkit.pdf>

initrdとは

- ファイルシステムをマウントするためのファイルを圧縮したもの
- 初期のブートプロセスで使われる
- initrd がロードされると、ファイル・システムを使用可能にするためのkernel moduleなどが読み込まれ、/ 以下のファイルシステムがマウントされる

ブートプロセスのどの辺か？

- UEFI
- shim
- grub
- linooks
- initrd
- systemd
- app



initrdを見てみる

- /boot以下にシステムによって動的に生成される
 - なぜ？
 - 環境の差異（ハードウェア、ファイルシステム etc）によってファイルを変える必要がある
 - ソフトウェア・アップデートによって動的に更新される

```
$ ls -l /boot (一部省略)
```

```
drwxr-xr-x 5 root root      4096 Dec  9 06:40 grub
```

```
-rw-r--r-- 1 root root 20566118 Dec  9 06:41 initrd.img-3.19.0-80-  
generic
```

kernelより新しい

```
-rw----- 1 root root  6595152 Jan 13  2017 vmlinuz-3.19.0-80-generic
```

initrdより新しい

initrdを見てみる

- gzipで圧縮されている
- コマンドのバイナリ、ファームウェアなどが含まれている

```
$ file /boot/initrd.img-3.19.0-80-generic
/boot/initrd.img-3.19.0-80-generic: gzip compressed data, from Unix, last modified: Sat Dec 9
06:40:55 2017
```

```
$ gunzip --to-stdout /boot/initrd.img-3.19.0-80-generic | cpio -tv (一部省略)
```

-rwxr-xr-x	1	root	root	1600	Jun 13	2017	bin/insmod
-rwxr-xr-x	1	root	root	976	Jun 13	2017	bin/dmesg
-rwxr-xr-x	1	root	root	4872	Jun 13	2017	bin/run-init
-rwxr-xr-x	1	root	root	3904	Jun 13	2017	bin/dd

initrdを使うのか

- initrdの中にある run-init を書き換える
- ブート時にrootkitのプロセスを生成する
- initrdは動的に生成され、システムの更新によって日時が変わるので、書き換えても気づかれにくい

おわりに

- 今日はlinux rootkitがlinuxのどんな仕組みを使っているか紹介しました
- 検知するには、OSSECやchkrootkit, rkhunterといったツールがある
- OSSとして公開されているrootkitをどれくらい検知できるか今後やっていく
- 次回作に期待してください！！！！

参考資料

- The magic of LD_PRELOAD for Userland Rootkits | FIUxluS' Blog (http://fluxius.handgrep.se/2011/10/31/the-magic-of-ld_preload-for-userland-rootkits/)
- エンタープライズ：第5回 kernel rootkitの概要 (<http://www.itmedia.co.jp/enterprise/0306/10/eptn12.html>)
- @IT：インシデントレスポンスははじめの一步 第4回 侵入者が仕掛けるLKM rootkitの実情 (<http://www.atmarkit.co.jp/fsecurity/rensai/rootkit04/rootkit02.html>)
- The Horse Pill Rootkit vs. Forcepoint Threat Protection for Linux | Forcepoint (<https://blogs.forcepoint.com/security-labs/horse-pill-rootkit-vs-forcepoint-threat-protection-linux>)

解析に役立つ資料

Linux Rootkit Detection With OSSEC

- <https://www.sans.org/reading-room/whitepapers/detection/rootkit-detection-ossec-34555>
- OSSECによるRootkit検出について書かれたSANSが出している資料

Malware memory analysis of the Jynx2 Linux rootkit (Part 1)

- <http://www.dtic.mil/get-tr-doc/pdf?AD=AD1004190>
- Volatilityを使ってJynx2のメモリダンプを解析するDRDC(カナダ防衛研究開発)の資料